

Authentication & Authorization Requirements

Purpose

This document defines the authentication and authorization requirements for users accessing the SecOpsAI platform.

Authentication Requirements

- All users must authenticate before accessing protected resources
- JWT tokens shall be used for authentication
- Tokens shall have an expiration period
- Invalid or expired tokens shall be rejected
- User credential shall be transmitted securely over HTTPS

User Roles

The platform shall support the following roles:

Administrator

- Manage users
- View all alerts and logs
- Configure platform settings

Security Analyst

- View alerts
- Investigate incidents
- Accessing security reports

Viewer

- View dashboards and reports
- No administrative privileges

Authorization Requirements

- Role Based Access Control (RBAC) shall be enforced.
- Users shall only access resources assigned to their role
- Administrative functions shall be restricted to administrators
- Unauthorized requests shall be denied

Session Management

- Session shall expire after token expiration.
- Users shall re-authenticate after session expiry.
- Logout functionality shall invalidate active sessions where applicable.

Audit and Monitoring

- Login attempts shall be logged.
- Failed authentication attempts shall be recorded.
- Privileged actions shall be auditable.

Conclusion

These requirements help ensure that only authorized users can access SecOpsAI resources while maintaining accountability and security.